

PHASE 2 ARCHITECTURE

1. Attack Templating

❖ Input:

- Simulated logs (EHR user activity: login, file access, prescription edit, logout etc).
- Attack vectors (CAPEC, CWE, CVE datasets).

❖ Process:

- Map CVE vulnerabilities → CWE weaknesses → CAPEC attack patterns.
- Build **graph templates** (nodes = actions, edges = transitions).
- Example: CAPEC Brute Force → repeated login failures → successful login.

❖ Output:

- **Fingerprint Graph DB** (MongoDB) containing both normal patterns and attack subgraphs.

2. Behavioral Fingerprinting

❖ Process:

➤ Probabilistic Model (HMM):

- Learns baseline user behaviour from normal sessions (trained in Phase 1).
- Scores each new sequence with probability.

➤ Subgraph Matching (VF2 + Graph Edit Distance):

- Matches user activity graph against known CAPEC attack graphs.
- Allows structural variations while still catching patterns.

❖ Decision Logic:

- If probability is **high** → Normal behaviour.
- If probability is **low** AND matches CAPEC subgraph → Malicious.

❖ **Output:**

- Binary label: **Normal / Malicious**.
- Threat score associated with anomalous sessions.

3: Behavioral Analysis

❖ **Input:** Malicious-labelled sessions (from Step 2).

❖ **Process:**

- **Graph Neural Networks (GNNs):** Learn embeddings of activity graphs to detect patterns missed by HMM.
- Acts as a **second filter** for structural anomalies.
- Produces refined threat score.

❖ **Decision:**

- If **threat score < threshold** → normal operations.
- If **threat score ≥ threshold** → send to threat response.

❖ **Output:**

- Threat score per session. Each session tagged with a risk score (low/high).

4: Threat Response

❖ **Sandboxed Environment (Digital Twin):**

- Replays user's suspicious activity in a controlled clone.
- Predicts **next likely action**.
- If it looks **dangerous** (file exfiltration, privilege escalation, etc.), the user is **blocked**.
- Otherwise, activity is allowed to continue in the real system.

❖ **Deception Layer:**

- Attackers redirected to **honeypots, fake assets, decoys**.
- Slows them down and collects intelligence.

❖ **Output:**

- **Twin Anomaly Report** with details of attacker's actions.

5: Observability & Explainability

- ❖ **Alerting System:** Grafana + Wazuh used for visualization and alert generation.
- ❖ **Explainable AI (XAI):** SHAP values highlight which actions or features contributed to the detection.
- ❖ **Dashboard:** Admins view:
 - User graphs.
 - CAPEC attack type matched.
 - Probability and threat scores.
 - Digital Twin reports.
- ❖ **Output:**
 - Interactive visualization of anomalies.
 - Human-readable explanations for decisions.

Phase 2 Workflow (Overall)

1. **Simulated logs** + CAPEC/CWE/CVE → Attack Templates → Fingerprint Graph.
2. Logs scored using **HMM** + **VF2 subgraph matching** → Normal/Malicious.
3. Malicious logs → **GNN analysis** → Refined threat scores.
4. High-threat sessions → **Digital Twin sandbox + Deception Layer**.
5. **Alerts & Explainability** → Dashboard for admins.